

DNSWatch

Detection & Scoring Architecture Specification

detect.py — Revised Design v2.0

March 2026 — Baris | University of Roehampton

1. Architecture Overview

DNSWatch's detection layer (detect.py) analyses DNS event data produced by the extraction layer (main.py) and assigns a risk score to each unique domain observed in the capture. The revised architecture uses a four-layer approach to maximise detection accuracy while minimising false positives on legitimate infrastructure.

Every domain receives full analysis regardless of its trust status. No data is hidden or suppressed. The layers determine how the results are labelled and categorised, not whether analysis occurs.

2. Processing Pipeline

The detection pipeline processes domains in the following order:

Step 1 — Load and clean. Read the DNS events CSV from main.py. Filter out rows with blank qname. Parse all fields into appropriate types.

Step 2 — Group by domain. Collapse all rows into unique domain profiles. Each profile aggregates: first seen timestamp, most frequent source IP, total query count, all TTL values observed, all response codes, all record types, and all resolved IP addresses.

Step 3 — Extract parent domain. For each qname, extract the parent domain (e.g., cdn.google.com becomes google.com, images.bbc.co.uk becomes bbc.co.uk). This is used for the Tranco lookup and subdomain entropy calculation.

Step 4 — Tranco lookup. Check whether the parent domain appears in the Tranco top-N list. Record the rank if found. This does not skip any analysis — it adds a trust_context field to the domain profile.

Step 5 — Feature scoring. Apply all seven detection features to every domain. Each feature independently contributes points to the total score.

Step 6 — Multi-signal check. Count how many independent features triggered (scored above zero). If fewer than two features triggered, cap the score at 29 (Safe ceiling). Apply the correlation bonus if three or more features triggered.

Step 7 — Category assignment. Assign one of four categories based on score and Tranco status: Safe, Known-Safe, Suspicious, or Dangerous.

Step 8 — Output. Write two CSV files: alerts (Suspicious and Dangerous only) and scored (all domains including Safe and Known-Safe).

3. The Seven Detection Features

Each feature is scored independently. Points from all features are summed to produce the raw score, which is then capped at 100.

3.1 Shannon Entropy (Full Domain)

Measures the randomness of character distribution across the full qname string. High entropy indicates algorithmically generated domains consistent with DGA malware or DNS tunnelling encoders. Calculated using the standard Shannon formula over character frequencies.

Condition	Threshold	Points	Reason Tag
High	> 4.0	30	high_entropy
Moderate	3.5 – 4.0	20	moderate_entropy
Normal	< 3.5	0	—

3.2 Subdomain Entropy

Calculates Shannon entropy specifically on the subdomain portion of the qname (everything to the left of the parent domain). This isolates tunnelling payloads encoded into subdomains from naturally long but predictable CDN domain names. If a domain has no subdomain (e.g., google.com), this feature scores 0.

Condition	Threshold	Points	Reason Tag
High	> 4.0	30	high_subdomain_entropy
Moderate	3.5 – 4.0	15	moderate_subdomain_entropy
Normal	< 3.5	0	—

3.3 TTL Analysis

Examines the minimum TTL observed for the domain across all DNS responses. Attackers use very low TTLs in fast-flux attacks to rapidly rotate IP addresses. The minimum TTL represents the most aggressive rotation behaviour observed.

Important: TTL alone can never trigger an alert. This feature contributes to the score but the multi-signal requirement (Section 4) ensures it must co-occur with at least one other indicator.

Condition	Threshold	Points	Reason Tag
Very Low	< 30s	20	very_low_ttl
Low	30 – 300s	10	low_ttl
Normal	> 300s	0	—

3.4 NXDOMAIN Rate

Measures the proportion of NXDOMAIN (rcode 3) responses relative to total queries for each domain. DGA malware generates hundreds of random domains, most returning NXDOMAIN, before finding the one the attacker has registered. A high NXDOMAIN rate indicates potential DGA beaconing.

Condition	Threshold	Points	Reason Tag
High	> 0.5	30	nxdomain_burst
Elevated	0.3 – 0.5	20	elevated_nxdomain
Normal	< 0.3	0	—

3.5 Domain Name Length

Measures the total character length of the full qname string. Unusually long domain names are a strong indicator of DNS tunnelling, where data is encoded into the domain string itself. Legitimate domains rarely exceed 50 characters.

Condition	Threshold	Points	Reason Tag
Very Long	> 75 chars	25	very_long_domain
Long	50 – 75 chars	15	long_domain
Normal	< 50 chars	0	—

3.6 Digit Ratio

Calculates the proportion of numeric characters (0-9) to total characters in the qname, excluding dots. Algorithmically generated domains often contain high proportions of digits. Legitimate domains occasionally contain digits but rarely exceed 30% of the total string.

Condition	Threshold	Points	Reason Tag
High	> 0.4	20	high_digit_ratio
Elevated	0.3 – 0.4	10	elevated_digit_ratio
Normal	< 0.3	0	—

3.7 Unusual Record Types

Checks whether the domain was queried using DNS record types commonly abused for tunnelling. TXT records allow large payloads and are frequently used by tunnelling tools like iodine and dnscat2. NULL and ANY records are also exploited. Standard A, AAAA, CNAME, MX, NS, SOA, SRV, and PTR records are considered normal.

Condition	Threshold	Points	Reason Tag
Unusual types	TXT, NULL, ANY	15	unusual_record_type
Normal types	All others	0	—

4. Multi-Signal Requirement & Correlation Bonus

The multi-signal requirement is the primary mechanism for preventing single-indicator false positives. After all seven features are scored, the system counts how many independent features contributed points above zero.

If 0 or 1 features triggered: The raw score is capped at 29, placing the domain in the Safe category regardless of how high the single feature scored. This prevents a CDN domain with only a low TTL or only moderate entropy from being flagged.

If 2 features triggered: The raw score stands as calculated. No bonus, no penalty.

If 3 or more features triggered: A correlation bonus of 10 points is added to the raw score (before the cap at 100). This rewards convergence across multiple independent indicators, which is a strong signal of genuinely suspicious behaviour.

This design means that a domain must exhibit suspicious characteristics across at least two independent dimensions before it can be classified as anything other than Safe. This is consistent with how professional tools like Palo Alto DNS Security and Splunk URL Toolbox approach multi-signal correlation.

5. Tranco Top-N Popularity Check

The Tranco list is a research-oriented ranking of the top one million most popular domains on the internet, aggregated from Cisco Umbrella, Majestic, Farsight, Chrome User Experience Report, and Cloudflare Radar. It is maintained by the academic community, updated daily, and peer-reviewed (published at NDSS 2019). It replaces the deprecated Alexa Top 1M list.

5.1 How It Works

Before scoring, DNSWatch extracts the parent domain from each qname and checks it against a local copy of the Tranco top-N list (recommended: top 100,000). The check records two things: whether the domain was found, and its rank if so.

The Tranco check does not skip or suppress any analysis. Every domain still receives the full seven-feature treatment. What changes is the category assignment:

If the parent domain is in Tranco AND the score is 30 or above: The domain is categorised as Known-Safe instead of Suspicious or Dangerous. All feature scores and statistics are preserved in the output for analyst transparency.

If the parent domain is in Tranco AND the score is below 30: The domain is categorised as Safe, as it would be normally.

If the parent domain is NOT in Tranco: Normal category assignment applies (Safe, Suspicious, or Dangerous based on score).

5.2 Implementation Notes

The Tranco list is downloaded as a CSV file from tranco-list.eu and stored locally in the data/ directory. The tool loads this file on startup and creates a lookup dictionary mapping parent domains to their ranks. Parent domain extraction should handle both standard TLDs (.com, .org, .net) and country-code second-level domains (.co.uk, .com.au, .co.jp) correctly. The `tlsextract` Python library is recommended for this purpose.

5.3 Academic Justification

Using the Tranco list rather than a hardcoded whitelist is a deliberate design choice supported by published research. Hardcoded whitelists are brittle, opinionated, and do not scale. The Tranco list is data-driven, maintained externally, and covers infrastructure domains (CDNs, cloud services) that a manual list would inevitably miss. However, research has shown that even popularity lists can contain malicious domains, which is why DNSWatch preserves all scoring data and labels domains as Known-Safe rather than excluding them entirely.

6. Category Assignment Logic

After scoring and the multi-signal check, each domain is assigned one of four categories:

Category	Score Range	In Tranco?	Meaning
Safe	0 – 29	Either	Low score, no significant indicators triggered
Known-Safe	30+	Yes	Score would trigger alerts, but domain is globally popular. Signals likely explained by legitimate CDN/infrastructure behaviour.
Suspicious	30 – 59	No	Moderate score with multiple signals. Warrants analyst investigation.
Dangerous	60 – 100	No	High score with strong multi-signal convergence. Strong indicator of malicious activity.

The decision logic in pseudocode:

1. Calculate *raw_score* = sum of all seven feature scores
2. Count *features_triggered* = number of features that scored > 0
3. If *features_triggered* < 2: cap *raw_score* at 29
4. If *features_triggered* >= 3: add 10 bonus points
5. Cap *final_score* at 100
6. If *final_score* < 30: category = Safe
7. Else if *in_tranco*: category = Known-Safe
8. Else if *final_score* < 60: category = Suspicious
9. Else: category = Dangerous

7. Output Specification

detect.py produces two output CSV files. Both contain the same columns, differing only in which rows are included.

7.1 alerts_<basename>.csv

Contains only Suspicious and Dangerous domains, sorted by score descending. This is the analyst's primary triage file.

7.2 scored_<basename>.csv

Contains all unique domains including Safe and Known-Safe, sorted by score descending. This provides full transparency and supports evaluation metrics.

7.3 Output Columns

Column	Type	Description
qname	string	The queried domain name (full qname)

parent_domain	string	Extracted parent domain used for Tranco lookup
first_seen	timestamp	Earliest observation in the capture
src_ip	string	Most frequent source IP querying this domain
query_count	integer	Total number of DNS events for this domain
entropy	float	Shannon entropy of the full qname string
subdomain_entropy	float	Shannon entropy of subdomain portion only (0 if no subdomain)
min_ttl	float	Minimum TTL observed across all responses
nxdomain_rate	float	Proportion of NXDOMAIN responses (0.0 to 1.0)
domain_length	integer	Total character length of the full qname
digit_ratio	float	Proportion of numeric characters (excluding dots)
unique_subdomains	integer	Count of unique subdomains observed under the parent domain
record_types	string	Pipe-separated list of DNS record types observed
has_unusual_types	boolean	True if TXT, NULL, or ANY record types were observed
tranco_rank	integer/null	Tranco rank if found, null if not in list
features_triggered	integer	Number of features that scored above zero
score	integer	Final risk score after multi-signal check (0–100)
category	string	Safe Known-Safe Suspicious Dangerous
reasons	string	Pipe-separated list of triggered reason tags (e.g., high_entropy low_ttl)

8. Dependencies

Existing: Python 3.12, pandas

New: tldextract (for reliable parent domain extraction across all TLD types)

Data file: Tranco top 100K CSV, downloaded from tranco-list.eu and stored in `data/tranco_top100k.csv`

9. Design Rationale

This section explains the reasoning behind key design decisions for academic understanding and report writing.

9.1 Why Four Layers Instead of One?

No single technique eliminates false positives entirely. Professional DNS security tools like Palo Alto DNS Security, Splunk URL Toolbox, and EfficientIP DNS Intelligence Center all use layered approaches combining multiple independent strategies. Each layer in DNSWatch catches what the previous layer misses: the Tranco check handles known-popular infrastructure, subdomain entropy refines the entropy signal, the multi-signal requirement blocks single-indicator noise, and the seven-feature engine provides the actual detection intelligence.

9.2 Why Subdomain Entropy Alongside Full-Domain Entropy?

Research and practitioner experience (particularly from Splunk's URL Toolbox community and Hurricane Labs) show that CDN domains have naturally high full-domain entropy due to long descriptive names, but their subdomains are short and predictable. DNS tunnelling encodes data specifically into the subdomain portion. By calculating entropy at both levels, DNSWatch can distinguish between a CDN domain like `cdn-gl.imrworldwide.com` (high full-domain entropy, low subdomain entropy) and a tunnelling domain like `aGVsbG8gd29ybGQ.evil.com` (high subdomain entropy). The full-domain entropy catches DGA-style threats; the subdomain entropy catches tunnelling-style threats.

9.3 Why Tranco Instead of a Hardcoded Whitelist?

A hardcoded whitelist requires the developer to manually decide which domains are trustworthy, does not scale as new CDN infrastructure appears, and cannot be academically justified as anything other than opinion. The Tranco list is data-driven (aggregated from real DNS query traffic across multiple providers), maintained by the research community, updated daily, and published as a peer-reviewed resource (NDSS 2019). It is used by professional tools including Quad9's DNS resolver and numerous academic security studies. However, research by the Tranco authors themselves showed that even popularity lists can contain malicious domains, which is why DNSWatch labels flagged popular domains as Known-Safe rather than excluding them — preserving full transparency for the analyst.

9.4 Why Keep Full Transparency for Known-Safe Domains?

Professional SOC tools never hide data from the analyst. If a domain triggered scoring features, that information has forensic value even if the domain is likely benign. By showing all statistics alongside the Known-Safe label, DNSWatch allows an analyst to identify the rare case where a legitimately popular domain has been compromised, or where a malicious domain has artificially entered the popularity rankings. This is an industry-standard principle and demonstrates mature security engineering thinking.

9.5 Why These Specific Point Values?

The point values are calibrated so that no single feature can push a domain past the Suspicious threshold (30) on its own, reinforcing the multi-signal requirement. The highest single-feature score is 30 (entropy or NXDOMAIN), which combined with the multi-signal cap at 29 for single-feature triggers means a domain needs at least two features scoring to reach Suspicious. The Dangerous threshold (60) requires either multiple high-scoring features or

the correlation bonus from three or more triggers, ensuring that Dangerous is reserved for domains exhibiting broad suspicious behaviour across independent indicators.

9.6 Why TTL Cannot Trigger Alone?

TTL is the noisiest single feature. Legitimate CDN infrastructure routinely uses TTLs of 30 seconds or lower for performance-critical content delivery. During testing of the original DNSWatch prototype, TTL was responsible for the majority of false positives on Google, BBC, and Steam infrastructure. By ensuring TTL contributes to the score but cannot trigger an alert alone (enforced by the multi-signal requirement), the system acknowledges TTL's value as a corroborating signal while preventing it from generating noise independently.

9.7 Key Academic References

Salat L., Davis M., Khan N. — DNS Tunnelling, Exfiltration and Detection over Cloud Environments. *Sensors* 2023, 23, 2760. [Supervisor's own published research; directly informed the feature selection for entropy, TTL, and record type analysis.]

Le Pochat V., Van Goethem T., Tajalizadehkhoob S., Korczynski M., Joosen W. — Tranco: A Research-Oriented Top Sites Ranking Hardened Against Manipulation. *NDSS* 2019. [Peer-reviewed source for the Tranco popularity list methodology.]

Palo Alto Networks Unit 42 — Autoencoder Is All You Need: Profiling and Detecting Malicious DNS Traffic. 2024. [Industry reference for DNS traffic profiling and multi-signal detection approaches.]

Splunk — Random Words on Entropy and DNS / DNS Entropy Hunting and You. [Practitioner references for subdomain entropy analysis and false-positive lookup tables in operational SOC environments.]